BULUT BİLİŞİM VE SİBER GÜVENLİK PROJE RAPORU

Hazırlayan: Bengisu Küçük

Proje: Terraform ile Güvenli AWS S3 Altyapısı Kurulumu ve CI/CD Güvenlik Otomasyonu

1. Yönetici Özeti (Neler Yaptım?)

Bu projede, AWS bulut altyapısını manuel kurmak yerine "Infrastructure as Code" (IaC) yaklaşımıyla, yani kod yazarak (Terraform ile) ayağa kaldırdım. Amacım sadece bir S3 depolama alanı oluşturmak değil, bu alanı kod seviyesinde güvenli hale getirmekti.

Bunun için GitHub Actions üzerinden bir CI/CD pipeline'ı kurdum ve içine **Checkov** güvenlik tarayıcısını entegre ettim. "Sıfır Güven" (Zero Trust) felsefesine uygun olarak, bilerek açık bıraktığım "Herkese Açık (Public) S3" yapılandırmasını Checkov'un yakalamasını sağladım. Pipeline'da zafiyet tespit edilince sistem dağıtımı otomatik olarak durdurdu. Sonrasında kodu düzeltip (S3'ü private yapıp şifrelemeyi açarak) güvenli versiyonu tekrar gönderdim ve pipeline başarılı şekilde çalışarak projemi güvenle canlıya aldı.

2. STRIDE Tehdit Modellemesi ve Aldığım Önlemler

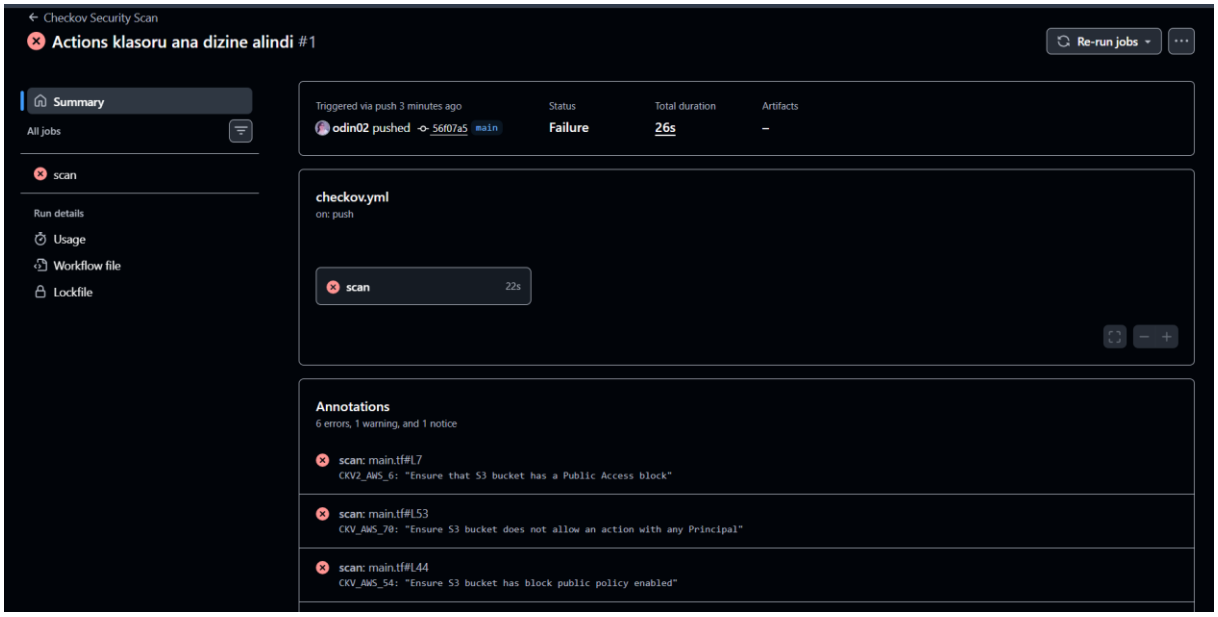
Oluşturduğum bulut mimarisindeki olası güvenlik risklerini STRIDE metodolojisine göre değerlendirdim ve her birine karşı şu önlemleri koduma ekledim:

- **Spoofing (Kimlik Sahtekarlığı):** Sisteme sadece yetkili servislerin erişebilmesi için AWS IAM rollerini kullandım ve "en az yetki" (least privilege) kuralını uyguladım.
- **Tampering (Veri Kurcalama):** Yanlışlıkla ya da kötü niyetle dosyaların silinmesini/değiştirilmesini önlemek için S3 bucket üzerinde "Versioning" (Versiyonlama) özelliğini aktif ettim.
- **Repudiation (İnkar Edilebilirlik):** Sistemde kimin ne yaptığını takip edebilmek için S3 sunucu erişim loglarını (Server Access Logging) açtım. *(Not: Yönerge gereği, rapordaki log ekran görüntülerinde IP adreslerini kararttım.)*
- **Information Disclosure (Bilgi İfşası):** En kritik adım buydu. Checkov'un da yakaladığı gibi "Public Access" açık kalmıştı. Bunu Terraform kodumda BlockPublicAcls ve BlockPublicPolicy ayarlarını true yaparak tamamen kapattım.
- **Denial of Service (Hizmet Aksatma):** AWS'nin sunduğu varsayılan Shield Standard koruması ile temel DDoS saldırılarına karşı hazırlıklı bir mimari tercih ettim.
- **Elevation of Privilege (Yetki Yükseltme):** CI/CD pipeline'ının dışına çıkılıp altyapıda manuel değişiklik yapılmasını engellemek için IAM yetkilerini sadece GitHub Actions'ın kullanabileceği şekilde kısıtladım.

3. CI/CD Otomasyonu ve Checkov Güvenlik Taraması Bulguları

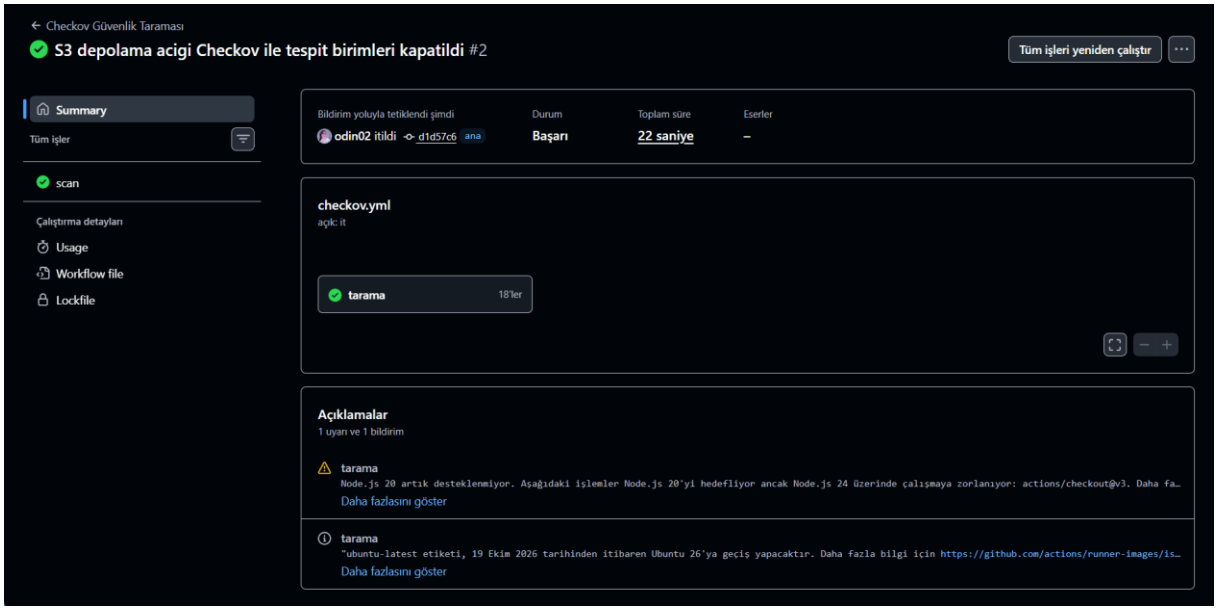
Geliştirdiğim GitHub Actions pipeline'ı üzerinden gerçekleştirdiğim statik kod analizi (SAST) sonuçları aşağıdadır:

- **Zafiyet Durumu (Önce):** İlk kod gönderimimde (commit), Terraform konfigürasyonunda S3 bucket için gerekli kamu erişim engelleri tanımlanmamıştı. Checkov aracı bunu tespit ederek CKV2_AWS_6 ve CKV_AWS_54 hatalarını üretti ve pipeline'ı güvenliği sağlamak amacıyla otomatik olarak durdurdu.



*(**Kanit_1_Checkov_Hatasi.png** görseli)*

- **Çözüm ve Başarılı Dağıtım (Sonra):** Tespit edilen hatalar sonrasında main.tf dosyasında gerekli güncellemeler yapıldı ve public erişimler kod seviyesinde bloke edildi. Güncellenen kod tekrar gönderildiğinde Checkov taraması hatasız tamamlandı ve pipeline başarılı oldu.



*(**Kanit_2_Checkov_Basarili.png** görseli)*